

CYROPAY LTD

Third-Party Vendor Risk Questionnaire

Document Classification: Internal
Document ID: VRA-Q001
Version: 1.0
Document Owner: Chief Information Security Officer (CISO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

Instructions

This questionnaire must be completed by all third-party vendors that process, store, or transmit CyroPay Ltd information, or that provide services critical to CyroPay's operations. Responses must be provided by the vendor's designated security representative and returned within 14 calendar days of receipt.

Each question must be answered as: Yes / Fully Met | Partial / Evidence Requested | No / Not Met. Where the response is Partial or No, the vendor must provide an explanation and, where applicable, a remediation timeline in the Notes column.

Completed questionnaires will be reviewed by CyroPay's Information Security team. CyroPay reserves the right to request supporting evidence (e.g. certificates, audit reports, policies) for any response.

Vendor Details

Field	Response
Vendor / Organisation Name	
Service Provided to CyroPay	
Date Completed	
Completed By (Name)	

Role / Title	
Email Address	
ISO 27001 Certified? (Y/N)	
SOC 2 Type II Report Available? (Y/N)	
PCI DSS Compliant? (Y/N)	

Section 1: Information Security Governance

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q01	Does the vendor maintain a formal Information Security Management System (ISMS) certified to ISO/IEC 27001 or equivalent?		A.5.1	Art. 5	
Q02	Does the vendor have a documented and board-approved information security policy suite reviewed at		A.5.1	Art. 5	

	least annually?				
Q03	Does the vendor have a named executive accountable for information security (e.g. CISO or equivalent)?		A.5.2	Art. 5	

Section 2: Access Control

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q04	Does the vendor enforce Multi-Factor Authentication (MFA) for all remote access, privileged accounts, and cloud administration?		A.5.17	Art. 9	
Q05	Does the vendor apply least-privilege principles and conduct formal access reviews at least quarterly?		A.5.18	Art. 9	

Q06	Does the vendor operate a Privileged Access Management (PAM) solution with session recording for administrator accounts?		A.8.2	Art. 9	
-----	--	--	-------	--------	--

Section 3: Data Protection

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q07	Is all data at rest and in transit encrypted using industry-standard cryptographic algorithms (AES-256, TLS 1.2+)?		A.8.24	Art. 9	
Q08	Does the vendor maintain a formal data classification scheme and apply handling controls proportionate to sensitivity?		A.5.12	Art. 9	

Q09	Does the vendor have documented data retention and secure deletion procedures for CyroPay data?		A.8.10	Art. 9	
-----	---	--	--------	--------	--

Section 4: Vulnerability Management

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q10	Does the vendor operate a formal vulnerability scanning programme with defined SLAs for critical patch deployment (e.g. 72 hours)?		A.8.8	Art. 9	
Q11	Does the vendor conduct annual external penetration testing by an accredited third party and share		A.8.29	Art. 9	

	summary findings?				
Q12	Does the vendor maintain a secure software development lifecycle (SDLC) with mandatory security testing prior to release?		A.8.25	Art. 9	

Section 5: Incident Response

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q13	Does the vendor maintain a documented Incident Response Plan tested at least annually?		A.5.24	Art. 17	
Q14	Will the vendor notify CyroPay of a security incident affecting CyroPay data within		A.5.26	Art. 19	

	24 hours of discovery?				
Q15	Does the vendor maintain an incident register and conduct post-incident reviews with remediation tracking?		A.5.27	Art. 17	

Section 6: Business Continuity & Resilience

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q16	Does the vendor have documented Business Continuity and Disaster Recovery Plans (BCP/DRP) tested at least annually?		A.5.29	Art. 11	
Q17	Are defined Recovery Time Objectives (RTO) and Recovery Point Objectives		A.5.30	Art. 11	

	(RPO) published and contractually committed?				
Q18	Does the vendor operate geographically redundant infrastructure to ensure continuity in the event of a site-level failure?		A.8.14	Art. 12	

Section 7: Supply Chain & Sub-processors

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q19	Does the vendor maintain a register of material sub-processors and fourth parties and assess their security posture?		A.5.21	Art. 28	
Q20	Does the vendor notify CyroPay of any material changes to its sub-		A.5.22	Art. 28	

	processor arrangements in advance?				
--	------------------------------------	--	--	--	--

Section 8: Audit & Compliance

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q21	Does the vendor hold current third-party assurance certifications relevant to the service (e.g. SOC 2 Type II, ISO 27001, PCI DSS)?		A.5.35	Art. 30	
Q22	Does the vendor contractually permit CyroPay (or its appointed auditor) to conduct or commission security assessments?		A.5.35	Art. 30	
Q23	Does the vendor have a formal compliance monitoring programme covering		A.5.36	Art. 5	

	applicable legal, regulatory, and contractual obligations?				
--	--	--	--	--	--

Section 9: Physical & Environmental Security

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q24	Are vendor data centres and facilities protected by physical security controls including access management, CCTV, and environmental monitoring?		A.7.1	Art. 9	

Section 10: Exit & Data Return

Q#	Question	Response (Yes / Partial / No)	ISO 27001	DORA	Notes / Evidence
Q25	Does the vendor have a documented exit plan		A.5.11	Art. 28	

	that guarantees return or secure deletion of CyroPay data within a defined timeframe upon contract termination?				
--	---	--	--	--	--

Scoring Guide

Response	Score	Meaning
Yes / Fully Met	2	Control fully implemented and evidenced
Partial / Evidence Requested	1	Control partially implemented or evidence outstanding
No / Not Met	0	Control not implemented — remediation required

Maximum Score

Maximum possible score: 50 (25 questions × 2). Vendors scoring below 35 (70%) will be subject to enhanced due diligence. Vendors scoring below 25 (50%) will be classified as High Risk and may be subject to contractual remediation requirements or escalation to the CISO.

Document Control

Version	Date	Author	Changes
---------	------	--------	---------

1.0	May 2026	CyroPay GRC Team	Initial version
-----	----------	---------------------	-----------------